

Narrativa Explicativa

Por qué esta encuesta TIBER-EU / TIBER-ES merece su tiempo

1. Una breve historia de pruebas, sustos y métricas

En un mundo ideal, la ciberresiliencia sería una virtud natural: los sistemas se defenderían solos, los atacantes se aburrirían y el CISO podría dedicar sus tardes a la filosofía de la ciencia. La realidad es un poco menos idílica: amenazas avanzadas, cadenas de suministro frágiles y un ecosistema regulatorio que, con DORA y TIBER-EU, ha decidido que ya no basta con “tener controles”, sino que hay que **probarlos en serio**.

Aquí entra TIBER-EU y, en España, TIBER-ES: un marco que propone pruebas de Red Team basadas en inteligencia de amenazas realista, ejecutadas sobre sistemas de producción y con la mirada atenta de supervisores y autoridades.

La encuesta que se le propone no es un capricho estadístico, sino un intento de capturar de forma estructurada lo que estas pruebas están cambiando (o podrían cambiar) en las organizaciones.

2. De la anécdota al dato

Quien haya vivido un buen ejercicio TIBER sabe que genera anécdotas memorables: esa credencial privilegiada que no debía existir, ese log que nadie miraba, ese tercer proveedor que se convirtió en protagonista inesperado.

El problema es que, sin métricas, todo se queda en anécdota, y las anécdotas envejecen mal en los comités de inversión.

Esta encuesta pretende:

- Convertir esas historias en indicadores comparables (MTTD, MTTR, cobertura de CIFs, porcentaje de remediación, etc.).
- Permitir a cada entidad situarse en un mapa de madurez sectorial.
- Dar a supervisores y policymakers una visión menos romántica y más accionable del estado real de la ciberresiliencia.

3. ¿Por qué TIBER-EU es un buen pretexto para hablar en serio?

TIBER-EU, en su versión 2025, y TIBER-ES ofrecen una virtud poco frecuente en los marcos de ciberseguridad: obligan a confrontar a la organización con **ataques plausibles**, no solo con checklists.

- Tienen una noción clara de función crítica o importante (CIF).
- Piden usar inteligencia específica (TTIR).
- Alinean los ejercicios con DORA y su régimen de pruebas TLPT.

Esta encuesta utiliza esa estructura como columna vertebral:

- Gobernanza y CIFs: ¿sabemos realmente qué es crítico para nosotros?
- Inteligencia: ¿nuestros escenarios se basan en amenazas reales o en creatividad literaria?
- Red Team / Blue Team / Purple Team: ¿cómo reaccionamos cuando alguien nos ataca “de verdad”, con permiso por escrito?
- Remediación y aprendizaje: ¿qué queda en pie cuando el humo de las presentaciones desaparece?

4. Ironía, pero con cariño

El tono de algunas preguntas y opciones de respuesta puede parecer ligeramente irónico. No es un accidente. Está pensado para:

- Romper la inercia del “todo está razonablemente controlado”,
- Invitar a una reflexión honesta (nadie es perfecto; casi todos tenemos MTTDs que preferiríamos no ver impresos),
- Hacer visible la diferencia entre lo que la documentación dice y lo que el día a día permite.

La ironía, bien usada, es una forma de respeto: presupone que el interlocutor es capaz de reconocer matices y de reírse de sí mismo mientras mejora.

5. Qué gana la entidad respondiendo con seriedad

Responder la encuesta con rigor implica esfuerzo, pero ofrece varios retornos:

- Mapa interno de madurez: forzará a consolidar información dispersa (SOC, TI, riesgos, continuidad) y a detectar huecos de datos.
- Argumentos ante el Consejo: los resultados (especialmente si se comparan con el sector) permiten sostener conversaciones menos defensivas y más estratégicas.
- Palanca para priorizar inversiones: vincular hallazgos TIBER con proyectos, presupuestos y expectativas de ROI.

En un contexto donde DORA y los supervisores miran cada vez más a la capacidad de **operar bajo ataque**, poder mostrar que se ha medido, comparado y aprendido cuenta más que una colección de políticas.

6. Qué gana el sector y el regulador

A nivel agregado, los datos de la encuesta permitirán:

- Identificar patrones: dónde está la mayor debilidad (detección, remediación, third-parties, etc.).
- Detectar buenas prácticas replicables entre entidades.
- Afinar la regulación y la supervisión, basándolas en evidencias, no solo en intuiciones o incidentes mediáticos.

Es, en cierto modo, una epidemiología de la ciberresiliencia: se necesitan datos para tratar al paciente sistema financiero, no solo síntomas aislados.

7. ¿Y si los resultados no son halagüeños?

Es posible que la encuesta revele que muchas entidades:

- No han cubierto aún todas sus CIFs.
- No han integrado bien el TTIR en su gestión diaria.
- No miden sistemáticamente MTTD/MTTR.
- No han cerrado todas las recomendaciones críticas.

Lejos de ser un drama, eso es un buen punto de partida honesto. El verdadero problema es no saberlo.

Además, los resultados pueden usarse de forma:

- Anonimizada: nadie necesita exponer a la plaza pública las vergüenzas concretas de cada entidad.
- Narrativa: combinando datos duros con historias de éxito y fracaso que permitan aprender sin señalar con el dedo.

8. Cierre: una invitación

Esta encuesta no va a resolver por sí sola los problemas de ciberresiliencia del país. Pero puede:

- Hacer visible lo que ahora es tácito.
- Generar un lenguaje común entre CISOs, reguladores y negocio.
- Ayudar a que las próximas iteraciones de TIBER-ES sean menos heroicas y más sistemáticas.

Si al terminar de responder siente que ha tenido que hablar con áreas con las que no hablaba lo suficiente, que ha descubierto datos que nadie consolidaba o que ha podido poner números a intuiciones antiguas, entonces el ejercicio habrá merecido la pena.

Y si además los resultados se convierten en un gráfico que convence a alguien de aprobar un proyecto largamente esperado, mejor aún.

Fin de la Narrativa Explicativa.